INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)
Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 4 Scenario-Based Assignment:

Compliance Management Crisis at TechFlow Industries

Student Name: Najma Abdi Omar

Reg. No: **2025/GRC/10331**

Date: 16/08/2025

Executive Summary:

TechFlow Industries is a rapidly growing financial technology company that provides payment processing solutions to small and medium-sized business across North America, as a company it has grown from a 15 to a 500 employee company and has acquired two smaller companies with differing regulations and way of operations, expanding operation and now having presence in three countries (USA, Canada and Mexico), this translates into more regulations and need for harmonization in order to support regulatory and industry compliance requirement.

Recently after a regulatory examination, TechFlow faced a compliance crisis involving two major compliance violations, a formal notice from Financial Crimes Enforcement Network (FinCEN) regarding deficiencies in Anti-Money Laundering and also probation placement from PCI SSC for potential violations of PCI DSS requirement which resulted from a security incident that exposed customer payment data. Key issues were identified ranging from governance, technical and operational inefficiencies.

TechFlow has 90 days to evaluate, examine internally and provide remediation plans failure to which could result in monetary penalties up to $500,000, regulatory monitoring, potential criminal charges, loss of license to operate as a bank and potential ban by PCI SCC. An internal audit has revealed several compliance gaps which will inform the assessment and remediation plan in this report.

In this report we have designed a compliance program which shows, compliance structure, a detailed compliance program charter and defined roles and responsibilities for key compliance positions. We have also developed policies and procedures for the crisis in hand in response to AML and PCI DSS and designed a

policy development and approval process with established review and update procedures, this development also contains communication and training plan. The report also includes a compliance risk assessment and monitoring plan where we have outlined risk assessment, curated a Risk Register, outlined monitoring and testing plan and defined escalation procedures. We have established documentation and reporting system guidelines where we have designed a document management system, compliance reporting template and KPI and dashboard guide, we have designed a report calendar which will form the basis for future report requirements in readiness for internal and external reports, establishing owners, audience and contributors. The report concludes with a roadmap in response to compliance violation, we have created phased approach with an initial 90 day response plan broken down into week scales, and concluded with a 12 month fragmented quarterly plan to achieve compliance, this has also informed our change management strategy and defined our success matrix which have been outlined and will be used in analysis of compliance milestones achieved.

1. Compliance Program Design

1.1 organizational structure, roles and responsibilities

We have mapped our organizational structure showing our key compliance positions in the overall organizational organogram as outlined in Appendix1.

Roles and Responsibilities:

For TechFlow, an organization with presence in multiple jurisdictions and an immediate compliance risk management need especially on AML laws and PCI DSS industry standard. It follows centralized management with the regional positions reporting to the central managers, each region has a manager and subject analyst. Refer to appendix 2 for detailed roles and responsibilities.

1.2 Compliance Program Charter

TechFlow Compliance Program Charter

I. Purpose

TechFlow is a growing Fintech with regional presence across three different countries and a growing customer base necessitating compliance with different regulations and standards. The purpose of this compliance program charter is to formally define the structure and authority of compliance function in TechFlow, it provides the framework to

ensure effective compliance with the applicable laws and regulations and especially Anti-Money Laundering (AML) and Payment Card Industry Data Security Standards (PCI DSS). This document outlines the different roles and responsibilities supporting TechFlow compliance.

II. Objectives

- Continuous Compliance with the laws and regulations and applicable industry standards
- Address key gaps identified in recent audit like lack of board oversite and lack of training
- Establish training needs and address gaps and inefficiencies.

III. Scope

TechFlow compliance program applies to all the business units across all the regional presence, including Canada, US and Mexico. It addresses a range of regulatory and compliance areas applicable to TechFlow focusing on AML and PCI DSS requirements. This ranges from customer due diligence, suspicious accounts reporting and other key requirements in AML to controls and adherence with PCI DSS control measure. It also focuses on training, monitoring and reporting. This program aims to remediate the immediate gaps that have been raised by FinCEN and PCI Security Standards Council to avoid further penalties, fines and license revoking, and beyond that, establish a flexible and scalable compliance framework that can support TechFlow even as it continues to scale and comply with best practices and requirement both internal and external.

IV. Compliance Function Authority

At TechFlow, the compliance function operates independently with no interference from any other arm in the organization, the structure and reporting line fully align with this objective where the CCO reports directly to the Board of Directors and has a dotted reporting line to the CEO. This gives staff members of compliance the autonomy to operate without conflict of interest and authority to engage, audit and even oversee certain functions across different units. The aim is to empower the compliance function to identify risk without fear of repercussions, and to encourage business units to cooperate and enable compliance efforts and reviews.

V. . Governance and Oversight

TechFlow compliance program is governed by layered structure which ensures oversight and accountability. We have the **board of directors** who are the ultimate decision makers and are responsible for how effective the compliance program is. The board receives regular updates from the CCO on the progress of compliance efforts and performance

of the program. The next layer is the oversight committee who meet quarterly and on emergencies, this is the **Compliance Committee** comprised of various stakeholders from different departments and chaired by the CCO. Their main task is to review compliance and monitoring efforts, oversee corrective actions and advice on change of regulation. The final layer of the governance is the CCO, **chief compliance officer.** This executive oversees and ensures execution of the compliance program, ensures all teams in all regions align and provides regular updates to both the Board of directors and the compliance committee. The governance framework ensures compliance by design.

VI. Roles and Responsibilities

The roles and responsibilities for the compliance function is clearly separated, with the lead or executive member reporting to the CEO and Board of Director, this is the Chief Compliance Officer (CCO) who is responsible for overseeing all compliance programs and acts as the bridge between the compliance teams and the governance team, this function also provides regular reports to the committee and governance team. The Compliance team is also composed of central managers who head the different roles of AML, PCI DSS and Monitoring and Training, this function report to the CCO. Under the managers we have independent (USA, Canada and Mexico) teams who are comprised of regional leads and analyst whose role is to ensure regional compliance and are subject matter experts in their respective jurisdictions. All employees are mandated to comply with controls and policies set, collaborate with the compliance team from training to reporting and to ensuring they follow guidelines in respective offices.

VII. Policy and Ethics Commitment

TechFlow organization is committed to conducting business with integrity, transparency and accountability. It expects ethical behavior from employees, leadership, board of directors and the third party vendors. It has established clear code of conduct, policies and procedures to ensure a customer centric, compliance-based interaction at all times. It is committed to providing leadership, training and compliance with applicable laws and regulations. All key players in the organization are expected to uphold the standards and report any violations with the provided whistleblower and other channels.

VIII. Program Review and Maintenance

The compliance program and this charter are living documents, it is expected to be reviewed annually and or in the case of an emergency, audit requirements or significant changes in compliance requirement to ensure continuous compliance and

to keep up with evolving laws and regulation applicable to the business industry and regional operations. Any changes made to the program or charter has to be reviewed and approved by Compliance committee and Board of Directors.

IX. Sign Offs

Approved by:

Chairperson, Board of Directors

12/08/2025

Chief Compliance Officer

Name: Najma Abdi Omar Signature: N.A.O

1.3. Governance Framework-TechFlow Industries

a) Board Oversight

Receives quarterly reports from the chief compliance officer and is ultimately responsible for overseeing the compliance program. It ensures compliance by reviewing risk, approving policies and providing support to the compliance committee.

b) Executive Sponsorship

The chief executive officer provides strategic leadership and ensures compliance by design, this function supports the chief compliance officer in coordination and collaboration of cross-functional units.

c) Compliance Committee

Comprising of different department heads from various backgrounds with a shared responsibility to support day-to-day governance of compliance function. It is chaired by chief compliance officer CCO.

d) Reporting Relationship

Apart from emergencies that trigger bypass of escalation matrix, from bottom up we have the lead analyst reporting to regional assistant managers and subject matter experts, who report to the compliance manager reporting to the chief compliance officer. The CCO reports functionally to the board of directors and has a dotted administrative reporting line to the CEO. This ensures total independence and authority to the compliance function.

e) Governance Review

The governance structure is reviewed annually by the chief compliance officer with input from the compliance committee and ultimate approval of the board. The review is annual unless necessary due to ad-hoc compliance governance change.

1.4. Reporting Relationship and Accountability:

TechFlow compliance function is operated through a centralized model with defined reporting lines to ensure independent, transparent and consistency across all regions and departments. This has been defined in a detailed table, refer to appendix 2.

2. Policy and Procedure Development

2.1 Framework Document

A. Introduction:

TechFlow operates across three different countries and is a growing fintech with multiple compliance requirement, this necessitates standardized approach to compliance to ensure consistent compliance even with regional differences. Recently TechFlow has been flagged by both FinCEN and PCI DSS due to issues identified and a key finding was lack of consistent policies across different business units, this and other audit findings contributed to the need for a central framework whose key objectives is to establish a clear system for developing, approving, maintaining and communicating policies across the organization.

B. Policy Hierarchy

TechFlow will adopt a three-tiered policy hierarchy to enable alignment across the organization, support regulatory compliance and to align with separate functional and operational layers, while maintaining consistency and clarity to enforce in all regions and organizational levels, it ensures that high-level strategy is effectively translated into operational behavior across TechFlow multinational structure.

Tier 1- Organizational Wide Policies: High level policies applicable to all the organization, supporting compliance program, these are approved by the board of directors and are mandatory for all levels and offices in the organization this includes but not limited to Compliance program Charter, code of conduct and Risk Management policy.

Tier 2-Functional Policies: This are designed to address specific compliance areas or regulatory domains. They include actionable guidelines for the different units, approved by Compliance Committee and owned by compliance managers, these are like the policies formulated to address PCI DSS compliance, AML compliance

Tier 3- Standard Operational Procedures (SOPs): This support tier 2 by addressing policies that guide Business as Usual(BAUs) in order to meet regulatory compliance, they are owned by departmental heads or

line managers and are aligned to jurisdictional needs. These are procedures like KYC and Customer Due Diligence, employee onboarding checklist etc.

C. Policy Classification

Below table, outlines the classification method adopted in TechFlow, with sample policies detailed. It dictates the name of the policy and details of functional domain and owners, applicable region, policy type i.e. where it falls, the version subject to change with every review and current operational status whether in review or active.

Policy Name	Domain	Functional Owner	Geographic State	Policy Type	Version	Status
Anti-Money Laundering (AML) Policy	AML	Risk and Compliance	Global	Functional	V2.0	Under Review
PCI DSS Compliance Policy	PCI DSS	IT Security/Risk and Compliance	Global	Functional	V1.0	Under Review
Data Privacy and Protection Policy	Data Privacy	Legal/Risk	GLOBAL	Functional Policy	V1.2	Active
KYC and DD SOP	AML	AML Manager	Global	SOP	V2.0	Under Review

D. Ownership and Responsibilities

Role	Responsibilities
Policy Owner	Draft, reviews and owns the policy document
Compliance Department	Oversees implementation, provides oversight and quality assessment
Legal Department	Provide legal advice and interpretation across different regions
ICT Department	Control adoption, trainers and support of the implementation policy
Compliance Committee	Oversight, review, monitoring and approval
Board of Directors	Oversight, Compliance implementation support (Budget and mobilization), guide and approvals

E. Policy Review Cycle

All documents will be reviewed annually expect where ad-hoc changes have been necessitated due to audit findings or change in operation, regulatory or compliance requirement. This process will be owned by the respective compliance manager. Each revision must include a summary of changes made, the version number, date of last review and the name of approver with signature.

F. Communication and Training

Policies will be documented and shared with employees via various channels (email, compliance portal) where key highlights will be shared in form of a brief via the internal newsletter, town hall Q&A sessions facilitated the first month of adoption of new process. Trainings will be mandatory for all staff, specialized training for high-risk

roles like audit and IT. Trainings will be offered via TechFlow learning module and live instruction via the subject matter expert. Completion reports will be expected and assessment for effective training will be contracted, noncompliance will be escalated to the HR and Management. TechFlow encourages feedback and reports of compliance violation via whistleblowing channels and open door policies with a no retaliation clause.

2.2 Sample Policies

2.2.1 Anti-Money Laundering (AML) Policy

Policy Title	Anti-Money Laundering (AML) Compliance Policy
Policy Owner	AML Manager
Version	V3.0
Effective Date	September 2025
Review Date	September 2026
Geographic Scope	United States, Canada, Mexico
Policy Tier	Functional Policy

Purpose:

The purpose of this policy is to establish an improved framework to prevent, detect and report suspected money laundering and related financial crimes. This review is in response to the recent findings of inadequate measures in place which attracted penalties from FinCEN, it addresses concerns and ensures compliance with applicable regulations including the FinCEN guidelines and requirements, it will also cover regional compliance.

Scope:

This is applicable to all TechFlow employees, systems, merchant onboarding processes and financial transactions across all regions where TechFlow is operational.

Policy Statement

TechFlow is committed to ethical practices across all it operational centers and will implement risk-based approach to prevent the misuse of its system for money laundering and terrorist financing activities. This is inclusive of best KYC practices, transaction monitoring and regulatory reporting.

Roles and Responsibilities:

The whole organization has roles to play to ensure effective compliance and to avoid further violations, penalties and criminal charges. The main stakeholders are the AML manager who is the owner of this document and owns the AML program, they will oversee controls and lead audit initiative, the compliance analysts will conduct transaction monitoring and risk assessment and where necessary train staff to cover gap in skills, onboarding team are tasked with ensuring and verifying and initial KYC, and continuous screening. All employees should report suspicious activities and complete training initiatives and assessment that have been formulated.

Key Controls and Requirement

Controls and requirement are guided by the FinCEN AML Program Requirements, TechFlow commits to abide as per outlined:

KYC and CDD: customer thorough screening and identity verification before onboarding

Transaction Monitoring: establish mechanisms to automatically send alerts for high-risk activity

SAR Filling: within 30 days as stipulate by FinCEN guidelines.

Record Keeping: Classification of documents and adherence to 3 to 5year retention period depending on type of documents and guidelines given. Each document will be classified and retention period outlined.

Employee Training: Mandatory staff training for new staff, quarterly refresher for exiting staff and conducting sector specific training for high risk staff. All staff must complete assigned training and assessments.

Violation and Enforcement: We encourage reporting of witnessed violation through various channels including whistle blowing, non-compliance will be investigated by the compliance team. Failure to comply may result in disciplinary, expulsion or criminal implication.

Policy Review

The policy is set to be reviewed annually unless there is an ad-hoc emergency and approved by compliance committee.

2.2.2. **PCI DSS Compliance Policy**

Policy Title	PCI DSS Compliance Policy
Policy Owner	PCI DSS Manager
Version	V2.0
Effective Date	September 2025
Review Date	September 2026
Geographic Scope	Global
Policy Tier	Functional Policy

Purpose:

TechFlow is under probation and may face a ban on the license to operate card business and other penalties including reputational damage. PCI SSC has given the organization immediate requirement to implement security controls and compliance reporting. This document, defines controls and responsibilities to ensure TechFlow Compliance with the payment card industry security standard v4.0 in all stages and lifecycle of cardholder data.

Scope:

All TechFlow staff, networks, systems, and vendors that handle card holder data in any state are included in this scope.

Policy Statement:

TechFlow is committed to upholding the standards and guidelines set to comply with PCI DSS certification and maintaining full compliance preventing data breaches and maintain customer trust. It commits to ensure the policy is adopted and employee training is completed to ensure uniform compliance, and encourages escalation of non-compliance.

Roles and Responsibility:

All employees must follow the set controls, protocols and security procedures guiding on handling card holder data, vendors must adhere and confirm compliance, Compliance team coordinator, reports and updates, IT Security Team manages the technical controls and system, monitoring PCI DSS manager is the owner of this policy and leads PCI DSS implementation and audit.

PCI DSS Controls

Network Security: establish tried and tested firewalls, end point protection and prevention secure protocols,

Access control: implements RBAC (Role Based access) management, enforcing MFA and Privileged access management.

Data protection: adopt a DLP (Data loss Prevention) solutions to secure data in all its cycle, restrict data theft and apply data retention policies, encrypt card holder data in transit and stored.

Monitoring: established file integrity monitoring, network access monitoring and security operations center.

Vulnerability management: Undertake quarterly scans and VAPTs annually to confirm settings, long-term investment in a VAPT and Patch Management solution to ensure continuous scans and patches.

Vendor compliance: Undertake through initial vendor vetting and continuous reviews to confirm service provider's integrity and proof of PCI DSS certification and compliance.

Training and Awareness: Employee Training: Mandatory staff training for new staff, annual refresher for exiting staff and conducting sector specific training for high risk staff. All staff must complete assigned training and assessments.

Violation and Enforcement

We encourage reporting of witnessed violation through various channels including whistle blowing, non-compliance will be investigated by the compliance team. Failure to comply may result in disciplinary, expulsion or criminal implication.

Policy Review

The policy is set to be reviewed annually unless there is an ad-hoc emergency and approved by compliance committee.

2.3. Policy Development Process

TechFlow policy development is an 8-step process defined and outline below:

2.4. Policy Review Schedule and Responsibilities

The below table shows policy review schedule and responsibilities for sample policies. This is adopted across all the policies in the organization.

Policy Name	Policy Tier	Review Frequency	Responsible Owner	Approving Authority
PCI DSS Compliance Policy	Functional/Tier 2	Annually/ By Trigger	PCI DSS Manager	Compliance Committee/ Board of Directors
AML Compliance Policy	Functional/Tier 2	Annually/ By trigger	AML Manager	Compliance Committee/ Board of Directors
Third Party Vendor Policy	Operational/Tier 3	Annually/ License Renewal/Trigger	Procurement lead	Compliance Committee

3. Risk Assessment and Monitoring Plan

3.1. Risk assessment Framework

Purpose:

When an organization is operating in multiple jurisdictions, gaps in consistency is realized, this has already been flagged with potential penalties and risk of losing operating licenses, it has triggered a companywide risk restructure. This framework establishes a consistent risk-based methodology for identifying, evaluating and managing compliance risk across TechFlow industries' operations.

Scope:

This framework cuts across all regions (USA, Canada and Mexico) and all the business units handling regulated activities and have to adhere to laws and regulations like compliance with PCI DSS, AML, Data Privacy requirements and controls.

Risk Identification

Compliance assessment trigger identification of compliance risk, this can be triggered through: Regulatory Changes, Internal and External Audit Findings, External examination by regulatory bodies like FinCEN and PCI SSC, Incident reports after a minor or major disruption, and introduction of new business or ventures/

Risk Categories:

The external examination by regulatory bodies and internal audit findings have identified several compliance risk types, we can categorize risk types at TechFlow as: AML and KYC failures, Exposure of Card holder data and other controls under PCI DSS, Vendor risk associated with poor vendor vetting which led to onboarding non-compliant vendors and third party, training gaps and privacy law violation.

Risk Rating

Each risk is scored based on the criteria of likelihood x impact on a scale of 1-5 (1 low and 5 high). All risk will be scored: 1-5: low, 6-14: Medium and 15-25 High.

Risk owners:

At TechFlow we have adopted a subject matter expert lead/ manager approach and each risk will be owned by the designated owner in charge of the compliance.

Assessment frequency:

Risk assessment is considered a continuous event in TechFlow this shows commitment to compliance. However, Company-wide risk assessment will be undertaken annually unless triggered by an emergency. With considerations that TechFlow is growing in the industry, therefore it will also necessitate continuous assessment.

3.2 **TechFlow Compliance Risk Register**

Risk ID	Risk Name	Description	Potential Impact	Category	Methodology
R1	Lack of Board Oversight	Clear gap in board oversight and function with no establishment of compliance committee	Increases the risk of legal violation, financial penalties, regulatory action. Leads to poor risk management	Governance	Historical Data Analysis
R2	Inconsistent policies	Lack of standardized process and procedures with no policy review process in place	Undermined employee trust, exposure to legal and regulatory penalties, damage organizational credibility	Compliance /Governance	Historical Data Analysis
R3	Gap in Training	Lack of clear	Inconsistent	Compliance/	Historical Data

	and Communication	outlined training and communication process	understanding of rules, increased risk of non-compliance and error	Operational	Analysis
R4	Gaps in documentation and reporting	Inconsistent documentations and no presence of formal reporting structures	Increased risk of non-compliance, audit failures and legal exposure. Eventual brand damage	Compliance/ Governance/ Operational	Historical Data Analysis
R5	Limited Technological Capacity	Observed use of legacy systems, with no centralized GRC platform and real-time monitoring capabilities	Outdated/fragmented systems limit visibility, delay issue detection and increased risk of non-compliance, hard to implement controls consistently	Operational/ Compliance/ Strategic	Historical Data Analysis
R6	Lack of formal Compliance leadership	Lack of CCO and accountability structure	Lack of risk , policies , and responsibility ownership. Inconsistent compliance practices and gaps in accountability leading to increased exposure to violation attracting fines, penalties and loss of trust.	Governance/ Compliance	Historical Data Analysis

3.3 **Monitoring and Testing Plan**

Control Area	**Monitoring Activity**	**Frequency**	**Responsible Role**	**Testing Method**
Board Oversight	Minutes of Meeting, Board Member profiles	Quarterly	Audit	Audit Reviews
Policy Review and Formulation	Process and Version control,	Annually	Compliance Managers	Departmental Policy Audit
Training & Communication	Training Programs, Communication Process	Quarterly	HR/Operation	Assessments, Test exercises, departmental audits
Reporting and Documentation	Reporting dashboards, documentation procedures	Report-Weekly/ Documentation-Monthly	Monitoring Manager/ Data privacy lead	DLP Tools, Dashboards,
Technology Review	Vulnerability Checks, Patch management, tools usage, end of life, license	Ongoing	ICT Technical Manager	Vulnerability tests, vendor and system review, depreciation schedule
Leadership and Oversight	Role and responsibility reviews	Annually	HR	Regulatory guide and audit

3.4. Issue Escalation Procedures

Step1: Identification: Issues may be identified by monitoring, audit, whistleblowing, employee report or customer complaints. The issues should be logged and tracked.

Step2: Triage: This is where the analyst sifts through the reported or identified issues to check genuine cases, severity and assign an ID which will assist in assigning agent, tracking issue status.

Step3: Severity Based Escalation: the issues identified and assigned in step 2 have severity, this guides who to assign to and the SLA in place for closure based on criticality with issues ranging from Low to Critical.

Step 4: Investigation: The assigned agent or analyst gathers evidence and documentation to check for root cause and give way forward.

Step 5: Remediation and Reporting: This is an extension of step 4 where the assigned analyst can close the issue or provide the recommendation for remediation to be implemented, we also report and document what happened.

Step 6: Closure and Review: issue closed and fed into the knowledge base, the lesson learnt documented in step 5 advice on improvements. The issue is also flagged for repeat analysis.

4. Documentation and Reporting System

4.1 Document management system design

Introduction:

TechFlow was recently flagged for having an inconsistent documentation policy and lack of centralized compliance repository. In response, the organization aims to establish a centralized, secure and access-controlled Document Management System (DMS) that enables real-time collaboration, version control and audit trails for all compliance documentation.

DMS Features

The DMS will have capabilities of a true data loss prevention system, it will have the following:

Centralized Repository: To ensure harmonized compliance, all documents will be located centrally

Access Control: we will incorporate Role based access control, auto tracking of version in each review, audit trails and logs so we never have to ask who did what when and what changes were made, enable searches based on tags like region, regulation and year, auto archiving and retention settings where we set retention periods based on the policy.

Access and Security:

Access will be granted based on the role where the CCO, audit, legal have full admin rights and other roles assigned either read only, or read/write access. For security we will apply a multifactor authentication and ensure to encrypt stored data.

Platform Selection

The platform will be selected based on response to our requirements shared with vendor partners, on whether it meets all our requirements, no full commitment until a Proof of Concept is undertaken and analysis given on scope vs delivery.

4.2 Compliance Reporting Templates

Standard reporting templates in TechFlow have to include the title of the report, who is the report is intended for, reporting period, report periodicity and who owns or prepares the report before moving to the details of report. Below is a sample template which is a compliance summary report addressed to the board of directors and CEO.

Title: Internal Compliance Summary Report

Audience: The Board of Directors/ CEO

Reporting Periodicity/ Date: Quarterly/ January-March Report

Report Owner: Compliance Department

Sections	Details
Summary issue e.g. training completion	Details of completion e.g. % of completed

4.3. **KPI framework and dashboard mockup**

Below is a table with a sample KPI and Dashboard, this basically gives an oversight on owners of a control and how we measure success. Our status are: On Track, Managed Complete, At Risk and Needs Attention

KPI Name	Details Measured	Target	Frequency	Owner	Current Value	Status
Policy Review Completion rate	% of overdue review completed	100%	Annually	Compliance Manager	60%	At Risk
Training completion rate	Assessment and Completion % Rate	98%	Quarterly	HR/Risk	50%	Need Attention
Issue resolution time	% of incidents /issue passed SLA	<15%	Ongoing	Departmental Heads	<10%	On Track
monitoring	% of planned services done on time	99%	Ongoing	Departmental Head	80%	Managed
System Review and Upgrade	% reviews and updates done	99%	Ongoing	ICT	30%	Need attention

4.4 Compliance Reporting Calendar

This are sample reports included to demonstrate our template calendar, it includes details of report type, audience, owner, frequent and due date and who is responsible

Report Type	Audience	Owner/ Responsible	Frequency	Due Date	Units Consulted
Training Completion Report	HR/CCO	Training & Minitoring manager	Quarterly	End of Each Quarter	Legal, Risk and ICT
Issue Resolution Timelines	Departmental Heads	ITSM Manager	Weekly	End of Week	ICT/HR/Risk

5. Implementation Roadmap

Background:

Deficiencies in Anti- Money –Laundering requirements and a probation placement by PCI SSC has resulted in a compliance crisis that TechFlow Industry is trying to address with the below road map:

1) **90-Day Emergency Response Plan**

Detailed weekly actions with the need to address critical finding and execute actions that will show compliance efforts and regain stakeholder trust:

Week	Action
1-2	Establish Governance by: Appointing A CCO and forming a compliance committee.
2-4	Complete review and publish AML and PCI DSS policies
4-6	Embark on organizational wide employee training, mandatory on the key policies AML and PCI DSS

6-8	Self-audits to see readiness for AML and PCI DSS area of concern, this to give time for improvement
8-10	Submit the remediation plans initiated to show the steps taken for compliance to avoid penalties and license to operate revocation
10-12	Start the Centralized documentation plan and creation of DMS. Establish compliance monitoring

2) 12-Month Implementation roadmap

This is a long term plan to ensure harmony in the regions and different business units. Functions will be divided into quarters and progress review to be done continuously.

Quarter	Key Action
Q1	Different regions call for centralized documentation, launch a GRC platform and set up centralized documentation, compliance charter also to be finalized
Q2	All units to review and updates their policies, full assessment done and invest in human resources to cater for the differing jurisdiction.
Q3	Asses organizational wide health by conducting full internal audit, refining monitoring and reporting
Q4	Confirm internal compliance review and submit for external audit and certification.

3) Resource and Budget Estimate:

In the initial phase there will be a lot of investment, however, compared to the risk assessed, the fines, reputational damage and the loss of business attached to compliance, the return on investment justifies the expense. Below are the estimates of requirements:

Item	Budget Estimate	Details
Staff Recruitment	$450, 000 per year	Appointment of CCO and other support staff including regional subject matter experts
Unified GRC platform and a DMS	$250,000	This is a one-time fee to consult, evaluate, implement and get a license to operate
Training and Capacity Building	$100,000	Include branch visits, uniform brand emersion
Legal and Consultation	$200,000	End-to –End legal consultation and post
Tech Upgrade	$100,000	Review legacy systems, invest in Vulnerability and patch management.

4) TechFlow change management and communication plans

The aim is for all employees to understand importance of compliance, reason for emergency response. The below are the step:

Change Strategy: Explain why there are the changes happening and code of ethics when interacting with policies. For example, employees need to understand why we are implementing strict controls e.g to avoid penalties.

Continuous Engagement: This will be though leadership briefing, meeting regular, have session for Q&A where employees raise all questions with no prejudice or fear of repercussion,

Training: Establish clear and mandatory trainings, with disciplinary actions attached to non-attendance.

Feedback: Be open to feedback, provide whistle blower protection and share surveys to test effectiveness

Build a culture/Brand immersion: at the end of it, all roles should be clear and everyone understand their cybersecurity same, all employees should have shared values and security awareness.

5) Success Matrix:

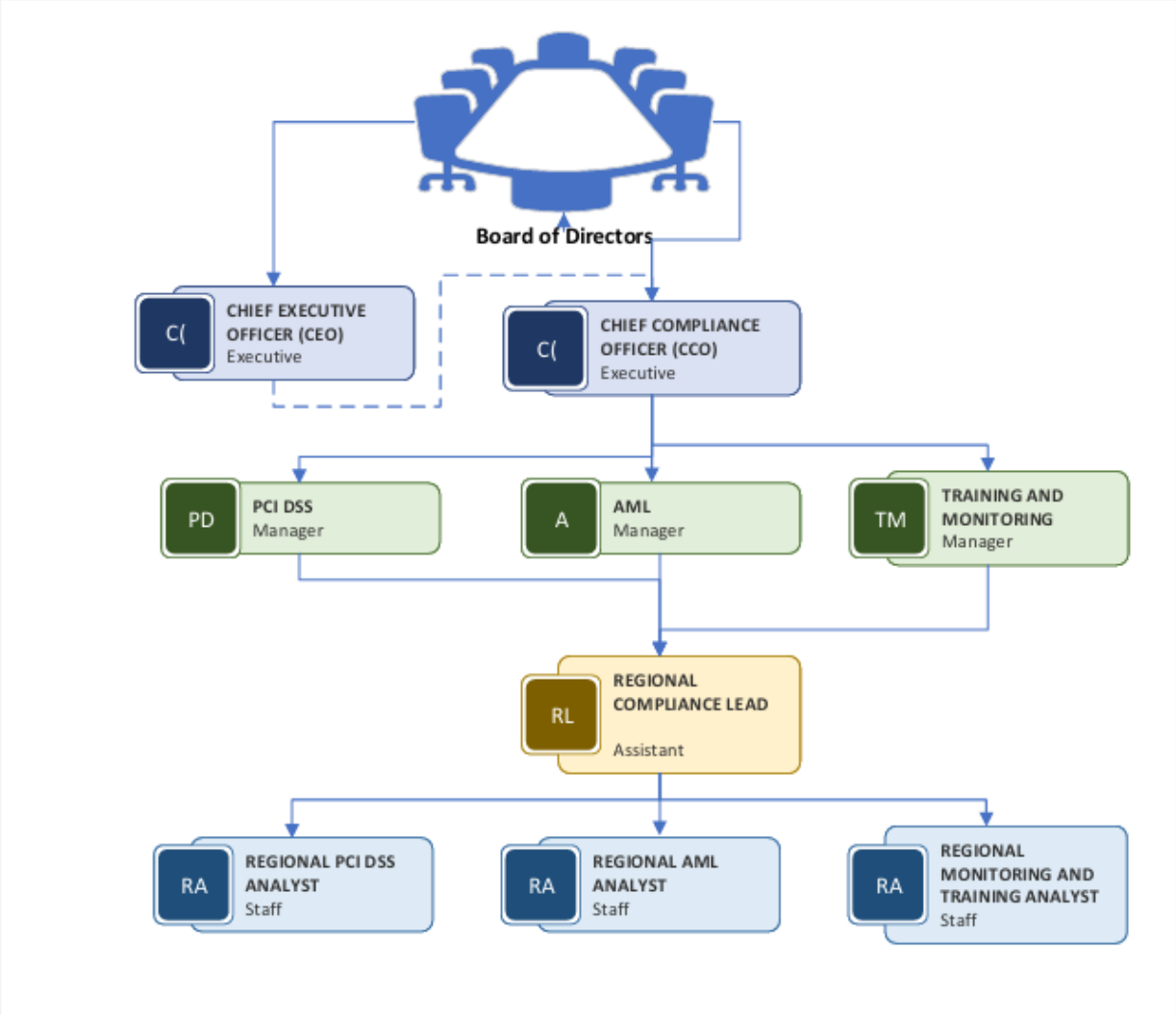
These are defined by how well we respond to the issues raised earlier. And our compliance health or posture improvement summarized in below table:

Metric	Target	Review Frequency
Resolution of issues raised by FinCEN and PCI SSC	98% by day 90	Initial weekly and later quarterly
Training completion	90% within first quarter	Quarterly
Policy Adoption by units	100% of units should have established clear compliancy	Annually
SLA on issues raised	Response time reduced now target <3 days	Ongoing
Internal checks like audit pass	>75% by year end	Quarterly

References:

1. ICDFA Study Guides- Week 1-4

2. ICDFA Additional Student Supplementary Study Resources



Appendix1. Organization structure of key Compliance Positions.

Role	Duties
Board of Directors	Provides strategic oversight and ensures compliance across the organization. Ultimate decisions and approval
CEO	Leads executive operations, liaison between board of directors and Chief Compliance officer.
CCO	Lead compliance function, oversees all compliance initiative ensuring regional alignment. Reports to CEO and Board of Directors
PCI DSS Manager	Manages PCI DSS compliance efforts, coordinates efforts with IT technical to ensure controls are in place to protect cardholder data. Reports to CCO
AML Manager	Oversees AML Compliance efforts including KYC, transaction monitoring and compliance with FinCEN and equivalent regulations. Reports to CCO
Monitoring and Training	Oversees Monitoring, reporting and training, also ensures compliance with all other industry and regulatory requirements. Reports to CCO
Regional Compliance Lead	Each country has separate lead all reporting to the same manager, oversees country compliance(US, Canada and Mexico), reports to subject manager
Regional Analyst(AML, PCI DSS, Monitoring and Training)	Same as the lead each analyst is a subject matter expert in their area country and regulation or law and task. Reports to regional compliance lead

Appendix 2: Table with detailed key compliance positions, roles and responsibilities.

Authors Note:

The insights and approaches discussed in this assignment are primarily based on the author's current role as an ICT Business analyst, where I engage with development and review of various key assignment given in this module. I also draw a lot of guidelines from the weekly resources provided by ICDFA.